

CoachOS Security & Compliance Policies — Zoom App Review

Sep 30, 2026 · @Ak

These are CoachOS's security and compliance policies, prepared for Zoom's App Marketplace production-access review of the `meeting:write:meeting` scope (the only Zoom API call CoachOS makes — creating a meeting under a coach's own connected Zoom account; see the Infrastructure & Dependency Management tab for the full "bring your own credentials" pattern this reflects).

Entity: RASS Consulting, operating CoachOS · **Security/privacy contact:** rassconsulting.co@gmail.com · **Effective:** 2026-09-30

Each requested document is its own tab:

- Security Policy
- Vulnerability Management Policy
- Data Retention & Protection Policy
- Incident Management & Response Policy
- Infrastructure & Dependency Management Policy
- Privacy Policy
- SOC 2 / ISO 27001 Statement
- Other / Supplementary Notes

A note on scale and honesty: CoachOS is a small, single-host SaaS product, not an enterprise with a dedicated security team. Every policy below describes what is actually true of the running system today — current controls are stated as such, and anything not yet in place is named as a gap rather than implied.

Security Policy

Effective: 2026-09-30 · **Owner:** RASS Consulting (rassconsulting.co@gmail.com)

Purpose and scope

This policy describes the controls CoachOS applies to protect customer and client data across the application (coachos.rass-consulting.com) and its integrations, including the Zoom connection requested in this review.

Access control

- Authentication is JWT-based (`djangoRESTframework-simplejwt`), issued on login and carried in `httpOnly` cookies — not reachable from client-side JavaScript, reducing exposure to XSS-based token theft.
- The client-facing portal authenticates through a second, isolated JWT scope carrying its own `client_id` / `workspace_id` claims and a distinct role, so a portal credential can never be replayed against staff-facing endpoints.
- Role-based access control (business owner, coach, assistant, limited, platform admin) is enforced on every API endpoint, with per-user, per-section view/edit/delete overrides available to the workspace owner.
- All business data is scoped to a Workspace (tenant); every database query is filtered by workspace, so no tenant can read or write another tenant's data.

Encryption

- All traffic is served over TLS 1.2/1.3 only; certificates are issued by Let's Encrypt and renewed automatically.
- Third-party API credentials a workspace supplies (Stripe, Zoom) are encrypted at rest, with the encryption key stored separately from the application's own signing key.
- OAuth tokens, including Zoom's, are stored server-side only — never exposed to the browser, and never written to logs in plaintext.

Application security

- Each workspace connects its own Zoom account directly — CoachOS never holds a shared Zoom account, meeting content, or customer funds (see Infrastructure & Dependency Management).
- OAuth scopes are requested at the narrowest grain that covers actual usage: `meeting:write:meeting` is the only Zoom scope requested, matching the single Zoom API call CoachOS makes (creating a meeting under the connecting user's own account).
- Optional error monitoring captures exception context for debugging; it is not configured to receive secret values, OAuth tokens, or full request bodies.

Monitoring

- An automated daily check verifies the public site is reachable and its TLS certificate isn't close to expiring, alerting the team by email on failure.
- An audit log records who viewed, created, updated, or deleted sensitive records (client data, team changes, password changes), reviewable by the workspace owner and by CoachOS's own platform administrators.

Workforce access

CoachOS is operated by a small team; production access (servers, database, admin console) is limited to the individuals who operate the platform. There is no outsourced support staff with standing production access today.

Review

This policy is reviewed at least annually, or sooner after a material change to infrastructure or a security incident.

Vulnerability Management Policy

Effective: 2026-09-30 · **Owner:** RASS Consulting (rassconsulting.co@gmail.com)

Purpose

Describes how CoachOS identifies, tracks, and remediates security vulnerabilities in its own code and in third-party dependencies.

Dependency management

- Backend dependencies (Python/Django) are version-pinned with explicit upper bounds in `requirements.txt` (e.g. `Django>=5.0,<5.2`), so a dependency never silently jumps to an untested major version.
- Frontend dependencies are managed the same way via `package.json` /npm.
- Dependency updates are currently applied manually when a security advisory is identified or a new patch release is available. Automated scanning (e.g. Dependabot or `pip-audit`) is not yet wired into the build pipeline — named here as a current gap, not a claim.

Application-level checks

- Django's own deployment checks (`manage.py check --deploy`) are run before production deploys, catching common misconfigurations such as debug mode left on or missing security headers.
- There is no scheduled automated SAST/DAST scanning today; code changes go through manual review before deploy.

Reporting a vulnerability

Anyone who discovers a security issue affecting CoachOS — including a Zoom reviewer — can report it to rassconsulting.co@gmail.com. We will acknowledge the report, investigate, and communicate a remediation timeline in good faith, appropriate to the size of the team.

Remediation

- Vulnerabilities found in CoachOS's own code are prioritized by severity and exploitability and fixed in the next deploy — deploys happen as changes are ready, not on a fixed release train.
- A vulnerability in a dependency is remediated by upgrading to the first patched version within the pinned range above, or by widening the pin if a patched version requires it.

Review

This policy is reviewed at least annually, or sooner after any vulnerability finding significant enough to change the process above.

Data Retention & Protection Policy

Effective: 2026-09-30 · **Owner:** RASS Consulting (rassconsulting.co@gmail.com)

Purpose and scope

Describes how long CoachOS retains personal and business data, and how that data is protected while retained.

What is retained

CoachOS retains the data a workspace enters to run its coaching practice: client records, session/calendar data (including the Zoom meeting link created via this integration), invoices and payments, documents, and the OAuth tokens needed to keep Zoom, Google Calendar, and Stripe connections working.

Retention period

- Data is retained for as long as the workspace remains active, or as needed to satisfy invoicing and financial record-keeping obligations — consistent with CoachOS's public Privacy Policy (coachos.rass-consulting.com/privacy-policy).
- There is no separate automated purge/expiry job today; deletion of a client's or a workspace's data is handled on request (below), not on a fixed timer. Named here as a current gap, not a claim of automated enforcement.

Protection while retained

- All business data is isolated per workspace at the database query layer — no cross-tenant access.
- Third-party credentials (Stripe/Zoom keys, OAuth tokens) are encrypted at rest; everything else is protected by TLS in transit and role-based access control in the application layer (see Security Policy).
- Database backups are taken on demand; there is currently no automated, scheduled backup job or offsite backup rotation — named here as a planned improvement, not a current guarantee.

Deletion on request

A workspace or one of its clients may request access to, correction of, or deletion of their personal information by contacting rassconsulting.co@gmail.com. Disconnecting a third-party integration (Zoom, Google Calendar) immediately deletes the stored OAuth token for that connection.

Review

This policy is reviewed at least annually, or sooner after a material change to what data is collected or how it's stored.

Incident Management & Response Policy

Effective: 2026-09-30 · **Owner:** RASS Consulting (rassconsulting.co@gmail.com)

Purpose

Describes how CoachOS detects, responds to, and communicates about security incidents, including any incident involving the Zoom integration or data accessed through it.

Detection

- Automated error monitoring captures unhandled application errors in production.
- A daily automated check verifies the site is reachable and the TLS certificate is valid, alerting the team by email on failure.
- An internal audit log and error log are reviewable by the workspace owner and CoachOS's platform administrators, surfacing unusual access patterns after the fact.
- Reports from users, customers, or third parties — including Zoom — are a direct detection channel (see the Vulnerability Management Policy for the reporting address).

Response process

1. **Triage** — confirm the report, assess scope (which workspaces, data, or integrations are affected) and severity.
2. **Containment** — for a compromised credential (a leaked API key or OAuth token), revoke or rotate it immediately; for a code-level vulnerability, deploy a fix or temporarily disable the affected feature.
3. **Eradication and recovery** — apply the permanent fix, verify it in the affected environment, restore normal operation.
4. **Notification** — affected workspaces are notified without undue delay once the facts are established; where a third-party integration (Zoom, Google, Stripe) is implicated, that provider is notified as well.
5. **Post-incident review** — a short written summary of what happened, its impact, and the follow-up action taken, kept on file.

Roles

As a small team, incident response today is handled directly by the people who operate the platform rather than a dedicated security/IR team — named here as the current state, not an aspirational one.

Review

This policy is reviewed at least annually, and after any incident that reveals a gap in the process above.

Infrastructure & Dependency Management Policy

Effective: 2026-09-30 · **Owner:** RASS Consulting (rassconsulting.co@gmail.com)

Purpose

Describes how CoachOS's production infrastructure is run, and how its dependency on third-party services — including Zoom — is managed.

Infrastructure

- CoachOS runs on a single AWS EC2 host, with PostgreSQL, Redis, and OnlyOffice Document Server co-located, orchestrated via Docker Compose.
- nginx terminates TLS and routes traffic to the Django/gunicorn API, a Celery worker and beat scheduler for scheduled and async jobs, and the built static frontend.
- There is no multi-region or auto-scaling infrastructure today — this is an appropriately sized single-host deployment for current traffic, not a claim of enterprise-scale redundancy.

Third-party integrations — "bring your own credentials"

- Stripe and Zoom both work by each workspace (coach) connecting their own account — CoachOS never holds a shared Zoom account, a shared Stripe account, customer funds, or meeting content on anyone's behalf.
- Zoom scope requested: `meeting:write:meeting` only. The single Zoom API call CoachOS makes is creating a meeting under the connecting coach's own Zoom account at session-scheduling time. CoachOS does not read Zoom meeting recordings, chat, participant data, or any other Zoom resource.
- Google Calendar and Stripe follow the same per-user, per-workspace "own credentials" pattern.

Dependency management

- Application dependencies are explicitly version-pinned rather than left to float to "latest" (see Vulnerability Management Policy).
- Infrastructure dependencies (Postgres, Redis, nginx, OnlyOffice) are pinned to specific image versions, upgraded deliberately rather than automatically.
- Each outbound dependency on a third-party service (Stripe, Zoom, Google Calendar, our email provider) is isolated to its own narrowly scoped integration module, so an issue on one provider's side doesn't cascade into unrelated functionality.

Change management

- Deploys follow a documented, repeatable process rather than ad hoc manual edits to running containers.
- Database schema changes go through Django's migration system, applied in the same deploy step, so infrastructure and schema stay in lockstep.

Review

This policy is reviewed at least annually, or sooner after a material infrastructure change such as moving off a single host or adding a new third-party integration.

Privacy Policy

Authoritative version: coachos.rass-consulting.com/privacy-policy — published and legally binding. This tab is a reviewer-facing summary only, not a replacement.

Summary

CoachOS's published Privacy Policy covers: information collected (client/business contact and session data), payments, how information is used, sharing with service providers, data security, data retention and deletion, children's privacy, policy changes, and a contact address.

Current service-provider disclosure — a gap worth closing before submission

Today the "Sharing with service providers" section names Stripe (payments), cloud infrastructure/storage, and email delivery providers. **It does not yet separately name Zoom or Google Calendar**, even though both are now live integrations that process data on a workspace's behalf (meeting creation; calendar event sync).

Recommendation: add a line for each before or alongside this submission — e.g. "Zoom — meeting hosting, when a coach connects their own Zoom account to a session," and the equivalent for Google Calendar. Reviewers, at Zoom and elsewhere, commonly cross-check that a published privacy policy discloses exactly the integration being requested; this is a quick, low-risk fix that closes that gap.

Contact

Privacy requests: rassconsulting.co@gmail.com (the same address as every other policy in this document).

SOC 2 / ISO 27001 Statement

Status: CoachOS is not currently SOC 2 or ISO 27001 certified.

Context

CoachOS is a small, single-host SaaS product serving independent coaches and small coaching firms. A formal SOC 2 Type II audit or ISO 27001 certification requires a scale of dedicated compliance investment — an external auditor engagement and a continuous compliance program, typically 6–12+ months of evidence collection — that isn't yet proportionate to the size of the business.

Compensating controls in place today

In place of formal certification, the following controls are already live in production, detailed in the other tabs of this document:

- TLS 1.2/1.3 everywhere, and encryption at rest for third-party credentials (Security Policy)
- Role-based access control and workspace-level tenant isolation (Security Policy)
- Per-user audit logging of sensitive data access (Security Policy)
- A written incident-response process (Incident Management & Response Policy)
- A written vulnerability-reporting channel and a dependency-pinning practice (Vulnerability Management Policy)
- The "bring your own credentials" integration pattern — CoachOS never holds a customer's Zoom meeting content, Stripe funds, or a shared OAuth token across customers (Infrastructure & Dependency Management Policy)

Roadmap

Formal certification — most likely SOC 2 Type I/II, given it's the more common ask from B2B customers and partners — is on the roadmap as the business and customer base grow, without a committed date at this time.

Other / Supplementary Notes

App identification

- **App name:** CoachOS
- **Developer/account:** rassconsulting.co@gmail.com
- **Zoom scope requested:** `meeting:write:meeting` only
- **What it's used for:** creating a Zoom meeting under a coach's own connected account when they schedule a client session in CoachOS (see Infrastructure & Dependency Management Policy)

Business continuity

CoachOS runs on a single host today (see Infrastructure & Dependency Management Policy); there is no documented disaster-recovery/failover plan beyond on-demand database backups. If Zoom's form asks for a separate Business Continuity / Disaster Recovery policy, this is the honest current state to disclose, not a gap to paper over.

If Zoom's review needs something not listed here

This tab is a placeholder for anything on Zoom's actual submission checklist that doesn't map cleanly to the seven named documents in this doc. Say exactly what's being asked for — Zoom's form sometimes uses its own specific wording — and it can be added as its own tab, grounded in the real system the same way as the rest of this document.